

RISK ASSESSMENT METHODOLOGY

Acme Financial Services

Document Owner: Governance, Risk, and Compliance (GRC) Team

Approved By: Chief Information Security Officer

Document ID: RSK-002

Version: 1.0

Effective Date: June 2026

Review Frequency: Annual

Classification: Internal Use

Prepared by: Vearnell Israel

DOCUMENT CONTROL

Document Information	Details
Document Name	Risk Assessment Methodology
Document ID	RSK-002
Version	1.0
Document Owner	Governance, Risk, and Compliance (GRC) Team
Classification	Internal Use
Effective Date	June 2026
Review Frequency	Annual
Approval Authority	Executive Leadership Team
Framework Alignment	NIST CSF 2.0, ISO 27001
Next Review Date	June 2027

REVISION HISTORY

Version	Date	Description of Change	Author
1.0	June 2026	Initial Release	Vearnell Israel

1. PURPOSE

The purpose of this Risk Assessment Methodology is to establish a consistent and repeatable process for identifying, analyzing, evaluating, and treating cybersecurity risks affecting Acme Financial Services.

This methodology provides a structured approach for assessing threats, vulnerabilities, likelihood, and business impact to support informed risk management decisions and effective allocation of resources.

2. SCOPE

This methodology applies to all information systems, cloud services, applications, databases, third-party relationships, business processes, and information assets owned, managed, or utilized by Acme Financial Services.

This methodology shall be used by employees, contractors, information security personnel, risk owners, and business stakeholders involved in cybersecurity risk management activities.

3. RISK ASSESSMENT PROCESS

3.1 Risk Identification

Cybersecurity risks shall be identified through vulnerability assessments, audits, threat intelligence, incident investigations, regulatory requirements, vendor assessments, and management reviews.

3.2 Threat Identification

Threats considered during assessments may include phishing, ransomware, insider threats, unauthorized access, credential theft, cloud misconfiguration, third-party compromise, denial-of-service attacks, and data leakage.

3.3 Vulnerability Identification

Vulnerabilities may include weak passwords, excessive privileges, unpatched systems, inadequate monitoring, insecure configurations, insufficient training, and ineffective security controls.

3.4 Likelihood Assessment

Likelihood represents the probability that a threat could exploit a vulnerability and adversely affect business operations.

Likelihood shall be evaluated using the following scale:

Score	Rating	Description
1	Rare	Unlikely to occur
2	Unlikely	Could occur occasionally
3	Possible	May occur under certain conditions
4	Likely	Expected to occur
5	Almost Certain	Expected to occur frequently

3.5 Impact Assessment

Impact represents the severity of harm to confidentiality, integrity, availability, business operations, reputation, financial performance, or regulatory compliance.

Impact shall be evaluated using the following scale:

Score	Rating	Description
1	Low	Minimal impact
2	Minor	Limited operational impact
3	Moderate	Noticeable business disruption
4	Major	Significant operational or regulatory impact
5	Severe	Critical business, financial, or reputational impact

3.6 Risk Calculation

Risk scores shall be determined using the following formula:

Risk Score = Likelihood × Impact

3.7 Risk Rating

Risk scores shall be categorized as follows:

Risk Score	Rating
1 – 5	Low
6 – 10	Medium
11 – 15	High
16 – 25	Critical

3.8 Risk Treatment Options

Acme Financial Services shall manage risks using one of the following treatment strategies:

Mitigate – Implement controls to reduce likelihood or impact.

Accept – Formally acknowledge and retain the risk.

Transfer – Shift risk through insurance, contracts, or third parties.

Avoid – Eliminate the activity causing the risk.

3.9 Risk Ownership

Each identified risk shall be assigned to a designated risk owner responsible for monitoring, managing, and implementing treatment actions.

3.10 Risk Monitoring and Review

Cybersecurity risks shall be reviewed periodically to ensure risk ratings remain accurate and treatment activities remain effective.

Changes in business operations, technologies, regulations, threat intelligence, or incidents may require reassessment.

3.11 Existing Controls

Existing security controls shall be identified and documented during the risk assessment process to evaluate the effectiveness of safeguards already implemented by Acme Financial Services.

Examples of existing controls may include policies, technical safeguards, multi-factor authentication, endpoint protection, security awareness training, logging and monitoring capabilities, vulnerability management processes, and third-party security requirements.

Existing controls shall be considered when determining residual risk and selecting appropriate risk treatment strategies.

3.12 Residual Risk

Residual risk represents the level of risk remaining after existing controls and mitigation activities have been considered.

Residual risks shall be reviewed by risk owners and executive leadership to determine whether additional treatment actions are required or whether the remaining risk may be accepted.

4. RISK COMMUNICATION

Risk information shall be communicated to executive leadership, business stakeholders, and technical teams through risk assessments, dashboards, management reports, and periodic reviews.

Effective communication supports informed decision-making, accountability, and continuous improvement of the cybersecurity program.

4.1 Risk Reporting

Cybersecurity risks shall be summarized and reported through dashboards, risk registers, management reports, and executive summaries.

Risk reporting shall provide visibility into risk ratings, treatment activities, risk trends, and critical issues requiring leadership attention.

5. REVIEW AND APPROVAL

This Risk Assessment Methodology shall be reviewed annually by the Information Security team and approved by executive leadership.

Approved By:

Chief Information Security Officer

Date: _____

Executive Leadership Team

Date: _____